BEZPIECZEŃSTWO APLIKACJI I SYSTEMÓW MOBILNYCH

Zajęcia 2

Modelowanie zagrożeń i architektura

Mateusz Kawulok · rok akademicki 2026/27

MODELOWANIE ZAGROŻEŃ

Cztery pytania, które zadajemy przez cały semestr

1

Nad czym pracujemy?

Architektura i diagram przepływu danych

2

Co może pójść źle?

Zagrożenia według STRIDE

3

Co z tym zrobimy?

Zabezpieczenia i wymagania MASVS

4

Czy zrobiliśmy to dobrze?

Testy, audyt krzyżowy, checklista

DIAGRAM PRZEPŁYWU DANYCH (DFD)

Pięć elementów wystarczy



Encja zewnętrzna

Użytkownik, inna aplikacja, usługa płatności



Proces

Aplikacja mobilna, API, moduł logowania



Magazyn danych

Baza danych, pliki, Keychain, SharedPreferences



Przepływ danych

Żądanie HTTPS, intent, deep link, zapis do pliku



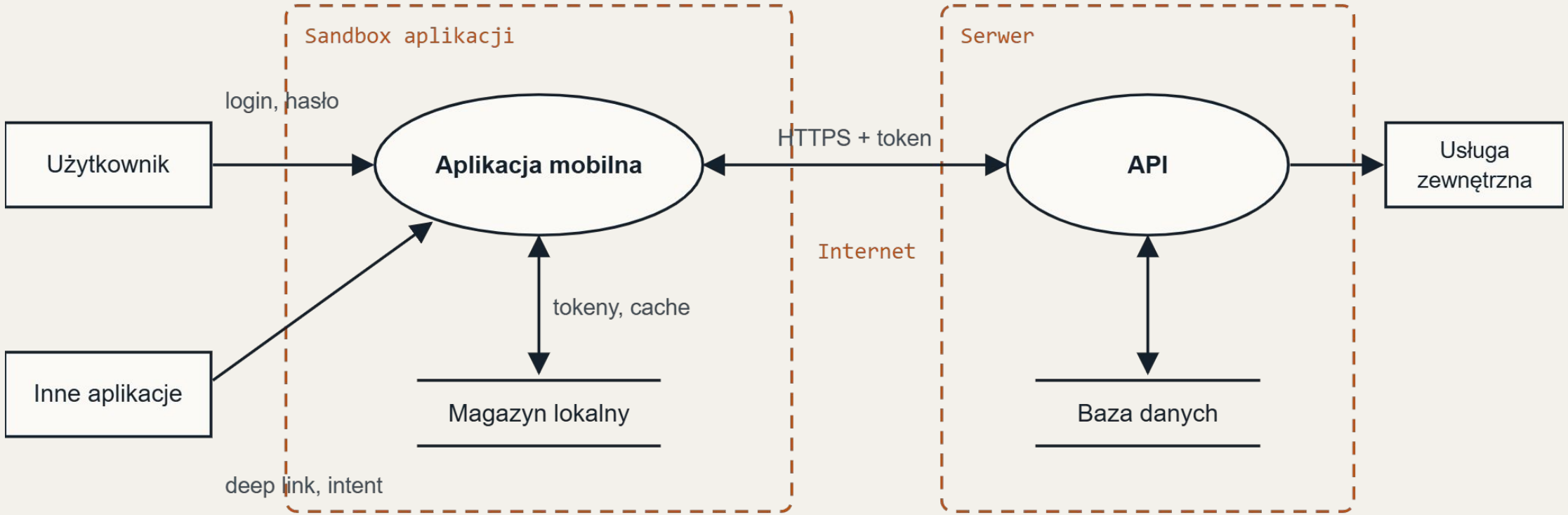
Granica zaufania

Miejsce, w którym zmienia się poziom zaufania

Najważniejsze są granice zaufania — każdy przepływ, który przez nie przechodzi, jest kandydatem na zagrożenie.

PRZYKŁAD

DFD typowej aplikacji mobilnej



GRANICE ZAUFANIA

Gdzie przebiegają w aplikacji mobilnej

Aplikacja ↔ sieć

Każde żądanie do API, CDN, usług zewnętrznych. Sieć jest zawsze niezaufana.

Aplikacja ↔ inne aplikacje

Deep linki, intenty, content providery, schemy URL, rozszerzenia.

Aplikacja ↔ system

Schowek, kopie zapasowe, logi, zrzuty ekranu, klawiatury firm trzecich.

Użytkownik ↔ urządzenie

Telefon może być zrootowany, zgubiony albo w rękach atakującego.

Backend ↔ usługi zewnętrzne

Płatności, powiadomienia push, analityka, logowanie przez dostawcę.

Kod ↔ biblioteki

Wtyczki Fluttera, moduły React Native, SDK — kod, którego nie pisaliście.

CO MOŻE PÓJŚĆ ŹLE?

STRIDE — sześć kategorii zagrożeń

	Zagrożenie	Narusza	Przykład w aplikacji mobilnej
S	Podszywanie (Spoofing)	uwierzytelnianie	Skradziony token, obca aplikacja przechwytuje deep link
T	Manipulacja (Tampering)	integralność	Zmodyfikowany APK, podmiana żądań przez proxy
R	Wypieranie się (Repudiation)	niezaprzeczalność	Brak logów serwera dla przelewu lub zmiany danych
I	Ujawnienie informacji	poufność	Token w logach, dane osobowe w kopii zapasowej
D	Odmowa usługi (DoS)	dostępność	Brak limitu prób na endpoincie logowania
E	Podniesienie uprawnień	autoryzacja	Zmiana userId w żądaniu daje dostęp do cudzych danych

METODA PRACY

STRIDE dla każdego elementu diagramu

Element DFD	Kategorie	Pytanie pomocnicze
Encja zewnętrzna	S R	Czy na pewno wiemy, kto to jest? Czy może się wyprzeć działania?
Proces	S T R I D E	Wszystkie sześć — proces jest najbardziej narażonym elementem
Magazyn danych	T I D (R)	Kto może czytać lub zmieniać dane? Czy logi są magazynem?
Przepływ danych	T I D	Czy ktoś może podsłuchać, zmienić albo zablokować przepływ?

Cel na dziś: **co najmniej 10 zagrożeń** dla waszej aplikacji, każde przypisane do elementu diagramu.

CO Z TYM ZROBIMY?

Prosta ocena ryzyka

	Wpływ niski	Wpływ średni	Wpływ wysoki
Prawdop. wysokie	**Średnie**	**Wysokie**	**Wysokie**
Prawdop. średnie	**Niskie**	**Średnie**	**Wysokie**
Prawdop. niskie	**Niskie**	**Niskie**	**Średnie**

Cztery decyzje

Zredukować — dodać zabezpieczenie

Wyeliminować — usunąć funkcję lub dane

Przenieść — np. na dostawcę logowania

Zaakceptować — świadomie i z uzasadnieniem

OD ZAGROŻENIA DO KODU

Każde zagrożenie kończy się wymaganiem

ZAGROŻENIE	STRIDE	RYZYKO	WYMAGANIE	KIEDY
Token sesji zapisany jawnym tekstem w pamięci aplikacji	I — ujawnienie informacji (magazyn lokalny)	Wysokie: częste błędy, pełne przejęcie konta	MASVS-STORAGE-1: bezpieczne przechowywanie danych wrażliwych	Zajęcia 4 — implementacja i dowód

Tak wygląda jeden wiersz waszego modelu zagrożeń. Na półmetku każdy wiersz ma status i link do dowodu.

NA CO UWAŻAĆ

Typowe błędy w modelach zagrożeń

Zbyt ogólnie

„Ktoś włamie się do aplikacji” nie jest zagrożeniem. Kto, którędy, po co?

Tylko aplikacja

Backend, baza danych i usługi zewnętrzne też są w zakresie.

Bez danych

Zagrożenie zawsze dotyczy konkretnych danych z karty projektu.

Bez granic zaufania

Diagram bez przerywanych ramek nie pokazuje, gdzie szukać.

Raz i koniec

Model aktualizujemy, gdy pojawia się nowa funkcja lub biblioteka.

Wszystko jest wysokie

Jeśli każde ryzyko jest wysokie, nic nie ma priorytetu.

NARZĘDZIA

Czym rysować — wybór należy do sekcji

OWASP Threat Dragon

Darmowe, open source, wbudowane STRIDE. Model zapisuje się jako plik JSON w repozytorium.

Microsoft Threat Modeling Tool

Automatycznie podpowiada zagrożenia, ale działa tylko na Windowsie.

draw.io / Excalidraw

Najszybszy start. Zagrożenia prowadzicie wtedy w tabeli w Markdown.

W REPO docs/threat-model/ — diagram (plik źródłowy + PNG) i tabela zagrożeń

ARKUSZ SEKCJI · 10 MIN

Wasza kolej

- ✓ Narysujcie szkic DFD: encje, procesy, magazyny, przepływy
- ✓ Zaznaczcie granice zaufania przerywaną linią
- ✓ Wybierzcie 3 przepływy przecinające granice — od nich zaczniecie STRIDE
- ✓ W arkuszu, punkt 1: gdzie u was są dane „poufne” i „szczególnie wrażliwe” z karty projektu

Zadanie

- ✓ DFD w docs/threat-model/ z granicami zaufania
- ✓ Model zagrożeń v1: min. 10 zagrożeń, STRIDE, ryzyko, decyzja
- ✓ MVP: ekran logowania i pierwsze połączenie z backendem
- ✓ Arkusz z dzisiejszych zajęć w docs/arkusze/